

CIRRUS

Cloud Security Assessment Report

ASSESSMENT TARGET AND SCOPE

Scan Session ID: 28870e55-a958-4685-adfc-73b9cf972261

Scan Config Name: PenTest

Target Account: Unknown Account ID

Audited AWS Region: us-east-1

Execution Date: 6/12/2026, 6:37:35 PM

Assessor Agent: Cirrus Autonomous AI Engine v1.2

CONFIDENTIAL - FOR INTERNAL REVIEW ONLY

1. Executive Summary & Scope

This document provides the technical audit details resulting from the automated cloud security assessment executed by Cirrus within the AWS environment. The objective of this automated assessment was to evaluate configuration baselines, detect vulnerabilities (such as open security groups or unencrypted storage), analyze IAM policy boundaries, and compile a secure remediation roadmap.

Assessment Results Summary

During the execution run, the Cirrus scan engine registered a total of 9 findings matching your configuration constraints. Action is highly recommended on any Critical or High severity findings.

2. Assessment Methodology

Assessment execution is handled by specialized AI security agents executing a ReAct (Reasoning and Acting) loop. These agents determine the optimal API actions to check resource structures against security compliance baselines. Each run is audited against native, read-only safety rules to prevent modifications during discovery.

- RECON Agent: Establishes initial authentication profile, lists active regions, aliases, and high-level posture.
- IAM Auditor: Evaluates roles, policies, group memberships, and credentials for privilege escalation risks.
- S3 Hunter: Reviews S3 block public access configurations, default encryptions, and bucket policies.
- EC2 Auditor: Inspects security groups, inbound firewall policies, and network-exposed configurations.

3. Vulnerability Summary Registry

Risk Classification	Total Findings Count
Critical Severity	1
High Severity	7
Medium Severity	1
Low Severity	0
Info / Audits	0

4. Detailed Finding Reports

[1] Multiple IAM Users Granted AdministratorAccess Privilege

Risk Severity: CRITICAL | Audited Service: IAM

Target Affected Resource:arn:aws:iam::195275680107:user/

Impact Analysis & Description:

The following users have been directly attached the 'AdministratorAccess' managed policy, violating the principle of least privilege and significantly increasing the impact of a potential credential compromise: 'agentcir', 'aws-backup-service', 'aws-support-agent', 'backup-admin', 'backup-service', 'blast-agent', 'detect', and 's3-backup-svc'.

Remediation Strategy:

Directly attaching the AdministratorAccess policy to multiple IAM users violates the principle of least privilege, dramatically increasing the risk of full account compromise if any of these credentials are leaked. The fix detaches the AdministratorAccess policy from these users so they can be reassigned job-specific, restricted permissions.

AWS CLI Remediation Commands

```
aws iam detach-user-policy --user-name agentcir --policy-arn arn:aws:iam::aws:policy/AdministratorAccess
aws iam detach-user-policy --user-name aws-backup-service --policy-arn arn:aws:iam::aws:policy/AdministratorAccess
aws iam detach-user-policy --user-name aws-support-agent --policy-arn arn:aws:iam::aws:policy/AdministratorAccess
aws iam detach-user-policy --user-name backup-admin --policy-arn arn:aws:iam::aws:policy/AdministratorAccess
aws iam detach-user-policy --user-name backup-service --policy-arn arn:aws:iam::aws:policy/AdministratorAccess
aws iam detach-user-policy --user-name blast-agent --policy-arn arn:aws:iam::aws:policy/AdministratorAccess
aws iam detach-user-policy --user-name detect --policy-arn arn:aws:iam::aws:policy/AdministratorAccess
aws iam detach-user-policy --user-name s3-backup-svc --policy-arn arn:aws:iam::aws:policy/AdministratorAccess
```

CloudFormation Remediation Playbook

```
AWSTemplateFormatVersion: '2010-09-09'
Description: 'Remediate AdministratorAccess by defining IAM users with restricted, task-specific managed policies.'
Resources:
  BackupAdminUser:
    Type: 'AWS::IAM::User'
    Properties:
      UserName: 'backup-admin'
      ManagedPolicyArns:
        - 'arn:aws:iam::aws:policy/AWSBackupFullAccess'
  BackupServiceUser:
    Type: 'AWS::IAM::User'
    Properties:
      UserName: 'backup-service'
      ManagedPolicyArns:
        - 'arn:aws:iam::aws:policy/AWSBackupFullAccess'
```

[2] IAM User with IAMFullAccess Attached

Risk Severity: HIGH | Audited Service: IAM

Target Affected Resource:arn:aws:iam::195275680107:user/cloudpilot-agent

Impact Analysis & Description:

The user 'cloudpilot-agent' has the 'IAMFullAccess' managed policy attached. This permission allows full control over IAM resources, which can be leveraged to escalate privileges, create backdoor administrative users, or modify security boundaries.

Remediation Strategy:

The 'cloudpilot-agent' user currently has 'IAMFullAccess' permissions attached, which poses a severe risk of privilege escalation and unauthorized administrative actions. Remediating this involves detaching the administrative policy and replacing it with a least-privilege policy tailored to the agent's exact requirements.

AWS CLI Remediation Commands

```
aws iam detach-user-policy --user-name cloudpilot-agent --policy-arn arn:aws:iam::aws:policy/IAMFullAccess
```

CloudFormation Remediation Playbook

```
AWSTemplateFormatVersion: "2010-09-09"
Description: "Remediates the IAM user by removing full IAM administrative access."
Resources:
  CloudpilotAgentUser:
    Type: "AWS::IAM::User"
    Properties:
      UserName: "cloudpilot-agent"
      ManagedPolicyArns: []
```

[3] SSH port 22 open to the world

Risk Severity: HIGH | Audited Service: EC2

Target Affected Resource:sg-01d35728fd3d42c6a

Impact Analysis & Description:

The security group sg-01d35728fd3d42c6a (launch-wizard-1) allows unrestricted inbound TCP access on port 22 (SSH) from any source address (0.0.0.0/0). This exposes the service to potential brute-force attacks or exploitation from the entire internet.

Remediation Strategy:

Allowing unrestricted SSH access on port 22 from 0.0.0.0/0 exposes your instances to brute-force attacks and potential compromise from anywhere on the internet. This remediation removes the open ingress rule to secure the instance, requiring administrative access to be restricted to a trusted CIDR range instead.

AWS CLI Remediation Commands

```
aws ec2 revoke-security-group-ingress --group-id sg-01d35728fd3d42c6a --protocol tcp --port 22 --cidr 0.0.0.0/0 -  
us-east-1
```

CloudFormation Remediation Playbook

```
AWSTemplateFormatVersion: '2010-09-09'  
Description: 'Remediated Security Group with restricted SSH access'  
Resources:  
  RemediatedSecurityGroup:  
    Type: 'AWS::EC2::SecurityGroup'  
    Properties:  
      GroupDescription: 'Remediated launch-wizard-1 with restricted SSH'  
      SecurityGroupIngress:  
        - IpProtocol: tcp  
          FromPort: 22  
          ToPort: 22  
          CidrIp: 192.0.2.0/24  
          Description: 'Restricted SSH access from trusted admin network'
```

[4] SSH port 22 open to the world

Risk Severity: HIGH | Audited Service: EC2

Target Affected Resource:sg-05e17a7bfd9ea12ab

Impact Analysis & Description:

The security group sg-05e17a7bfd9ea12ab (launch-wizard-3) allows unrestricted inbound TCP access on port 22 (SSH) from any source address (0.0.0.0/0), exposing the SSH daemon globally.

Remediation Strategy:

Allowing unrestricted SSH access (0.0.0.0/0) on port 22 exposes your EC2 instances to brute-force attacks and unauthorized access attempts from the entire internet. To secure the resource, you must revoke the open ingress rule and restrict SSH access to trusted IP ranges or administrative CIDR blocks.

AWS CLI Remediation Commands

```
aws ec2 revoke-security-group-ingress --group-id sg-05e17a7bfd9ea12ab --protocol tcp --port 22 --cidr 0.0.0.0/0 -  
us-east-1
```

CloudFormation Remediation Playbook

```
AWSTemplateFormatVersion: '2010-09-09'  
Description: 'Remediates open SSH port by creating a secure Security Group with restricted access.'  
Resources:  
  SecureSecurityGroup:  
    Type: 'AWS::EC2::SecurityGroup'
```

```
Properties:
  GroupDescription: 'Security group with restricted SSH access'
  SecurityGroupIngress:
    - IpProtocol: tcp
      FromPort: 22
      ToPort: 22
      CidrIp: 192.0.2.0/24
```

[5] AWS Root Account Has Active Access Keys

Risk Severity: HIGH | Audited Service: AWS General

Target Affected Resource: AWS Root Account

Impact Analysis & Description:

The AWS root account currently has 1 active access key (AccountAccessKeysPresent = 1). Best practice dictates that root credentials should not have active access keys to prevent accidental disclosure or compromise of administrative power.

Remediation Strategy:

Active root access keys grant unrestricted administrative access to your entire AWS account, posing a severe security risk if compromised. To remediate this, you must deactivate and permanently delete the root access keys, transitioning all administrative tasks to IAM Users or Roles with least-privilege policies.

AWS CLI Remediation Commands

```
aws iam update-access-key --access-key-id <YOUR_ROOT_ACCESS_KEY_ID> --status Inactive
aws iam delete-access-key --access-key-id <YOUR_ROOT_ACCESS_KEY_ID>
```

CloudFormation Remediation Playbook

```
AWSTemplateFormatVersion: '2010-09-09'
Description: 'Deploys an AWS Config Rule to continuously monitor and flag active AWS Root Account Access Keys.'
Resources:
  RootAccessKeyCheck:
    Type: 'AWS::Config::ConfigRule'
    Properties:
      ConfigRuleName: 'iam-root-access-key-check'
      Description: 'Checks whether the root user access keys are active.'
      Source:
        Owner: 'AWS'
        SourceIdentifier: 'IAM_ROOT_ACCESS_KEY_CHECK'
```

[6] S3 Public Access Block Disabled

Risk Severity: HIGH | Audited Service: S3

Target Affected Resource:exfil-staging-bucket-195275680107

Impact Analysis & Description:

The bucket exfil-staging-bucket-195275680107 has public access block configuration explicitly set to false for BlockPublicAcls, BlockPublicPolicy, IgnorePublicAcls, and RestrictPublicBuckets.

Remediation Strategy:

Disabling the S3 Public Access Block allows bucket data to be exposed publicly via ACLs or bucket policies, risking unauthorized data exfiltration. Enabling these four settings blocks all public access at the bucket level, overriding any permissive ACLs or policies.

AWS CLI Remediation Commands

```
aws s3api put-public-access-block --bucket exfil-staging-bucket-195275680107 --public-access-block-configuration "BlockPublicAcls=true,IgnorePublicAcls=true,BlockPublicPolicy=true,RestrictPublicBuckets=true" --region us-east-1
```

CloudFormation Remediation Playbook

```
AWSTemplateFormatVersion: '2010-09-09'
Resources:
  S3Bucket:
    Type: AWS::S3::Bucket
    Properties:
      BucketName: exfil-staging-bucket-195275680107
      PublicAccessBlockConfiguration:
        BlockPublicAcls: true
        BlockPublicPolicy: true
        IgnorePublicAcls: true
        RestrictPublicBuckets: true
```

[7] SSH port 22 open to the world

Risk Severity: HIGH | Audited Service: EC2

Target Affected Resource:sg-0802206e9164b9cbc

Impact Analysis & Description:

The security group sg-0802206e9164b9cbc (launch-wizard-2) allows unrestricted inbound TCP access on port 22 (SSH) from any source address (0.0.0.0/0). This exposes potential administrative interfaces to global attackers.

Remediation Strategy:

Allowing unrestricted SSH access (0.0.0.0/0) on port 22 exposes your resources to constant brute-force attacks and

unauthorized access attempts from anywhere on the internet. This fix removes the wide-open ingress rule, and you should replace it with a rule targeting a specific, trusted IP address or range.

AWS CLI Remediation Commands

```
aws ec2 revoke-security-group-ingress --group-id sg-0802206e9164b9cbc --protocol tcp --port 22 --cidr 0.0.0.0/0 - us-east-1
```

CloudFormation Remediation Playbook

```
AWSTemplateFormatVersion: '2010-09-09'
Description: 'Remediation template to create a secure security group with restricted SSH.'
Parameters:
  TrustedCidr:
    Type: String
    Description: 'The trusted CIDR block allowed to connect via SSH.'
    Default: '192.0.2.0/24'
Resources:
  SecureSecurityGroup:
    Type: 'AWS::EC2::SecurityGroup'
    Properties:
      GroupDescription: 'Remediated launch-wizard-2 with restricted SSH'
      SecurityGroupIngress:
        - IpProtocol: tcp
          FromPort: 22
          ToPort: 22
          CidrIp: !Ref TrustedCidr
```

[8] Running instance with public IP and risky security group

Risk Severity: HIGH | Audited Service: EC2

Target Affected Resource:i-08006f8a74caf2da2

Impact Analysis & Description:

EC2 instance i-08006f8a74caf2da2 is actively running with a public IP address (34.228.79.85) and has security group sg-05e17a7bfd9ea12ab assigned to it, which allows unrestricted SSH (port 22) access from any IP address (0.0.0.0/0). This combination significantly increases the host's attack surface.

Remediation Strategy:

Exposing SSH (port 22) to the entire internet (0.0.0.0/0) on a public EC2 instance invites continuous brute-force attacks. This remediation revokes the unrestricted ingress rule on security group sg-05e17a7bfd9ea12ab to close the security gap.

AWS CLI Remediation Commands

```
aws ec2 revoke-security-group-ingress --group-id sg-05e17a7bfd9ea12ab --protocol tcp --port 22 --cidr 0.0.0.0/0 - us-east-1
```


CloudFormation Remediation Playbook

```
AWSTemplateFormatVersion: '2010-09-09'
Description: Remediate public SSH access by deploying a restricted security group configuration.
Resources:
  RemediatedSecurityGroup:
    Type: AWS::EC2::SecurityGroup
    Properties:
      GroupDescription: Remediated SG with restricted SSH access
      SecurityGroupIngress:
        - IpProtocol: tcp
          FromPort: 22
          ToPort: 22
          CidrIp: 192.0.2.0/24
```

[9] Multiple Active Access Keys Configured for IAM Users

Risk Severity: MEDIUM | Audited Service: IAM

Target Affected Resource:arn:aws:iam::195275680107:user/

Impact Analysis & Description:

The users 'backup-admin', 'backup-service', 'cirrus-audit', and 's3-backup-svc' currently have multiple (two) active access keys. This exceeds the operational requirement of a single active key and doubles the potential credential exposure risk.

Remediation Strategy:

Having multiple active access keys per IAM user increases the risk of credential exposure. To mitigate this risk, identify the unused or secondary access key for each user and change its status to Inactive, leaving only one active key.

AWS CLI Remediation Commands

```
aws iam update-access-key --user-name backup-admin --access-key-id $(aws iam list-access-keys --user-name backup-admin --query "AccessKeyMetadata[1].AccessKeyId" --output text) --status Inactive
aws iam update-access-key --user-name backup-service --access-key-id $(aws iam list-access-keys --user-name backup-service --query "AccessKeyMetadata[1].AccessKeyId" --output text) --status Inactive
aws iam update-access-key --user-name cirrus-audit --access-key-id $(aws iam list-access-keys --user-name cirrus-audit --query "AccessKeyMetadata[1].AccessKeyId" --output text) --status Inactive
aws iam update-access-key --user-name s3-backup-svc --access-key-id $(aws iam list-access-keys --user-name s3-backup-svc --query "AccessKeyMetadata[1].AccessKeyId" --output text) --status Inactive
```

CloudFormation Remediation Playbook

```
AWSTemplateFormatVersion: '2010-09-09'
Description: 'Remediation template to define an IAM user with a single managed active access key'
Resources:
  BackupAdminUser:
    Type: 'AWS::IAM::User'
    Properties:
      UserName: 'backup-admin'
  BackupAdminAccessKey:
```

```
Type: 'AWS::IAM::AccessKey'  
Properties:  
  UserName: !Ref BackupAdminUser  
  Status: 'Active'
```

5. Conclusion & Recommendations

The findings detailed above highlight configurations that do not meet standard security best practices. Remediation actions should be prioritize-scanned to evaluate drift. High priority actions:

1. Restrict all wildcard permissions (*) in user-attached policies to follow least-privilege principles.
2. Enable default server-side encryption (SSE-KMS) and block public access on all S3 data stores.
3. Close security group access for sensitive administrative ports (22, 3389, 3306) open to the internet.
4. Establish weekly scheduled scans to detect configuration drift and baseline changes.